ASSIGNMENT 12

Document Vulnerabilities, Assign Risk Levels, and Recommend Mitigations

1. Introduction

Vulnerability documentation is an important part of cybersecurity because it records security weaknesses in a system, explains their possible impact, and helps teams prioritize corrective actions. A useful vulnerability report includes a clear description, affected asset, evidence, likelihood, impact, risk level, and recommended mitigation. This assignment describes a basic process for documenting vulnerabilities and assigning risk levels in an authorized assessment.

2. Objectives

- Understand the purpose of vulnerability documentation.
- Record security findings clearly and consistently.
- Assign risk levels based on likelihood and impact.
- Recommend practical mitigations and prioritize remediation.

3. Vulnerability Documentation Process

1. Identify the affected asset, such as a computer, application, server, or network service.
2. Describe the weakness in clear, factual language.
3. Record evidence such as configuration output, screenshots, logs, or scan results, while avoiding unnecessary sensitive data.
4. Explain realistic consequences if the weakness is exploited.
5. Estimate likelihood and impact, then assign a risk level.
6. Recommend mitigation, identify a responsible owner, and set a target date.
7. Retest after remediation and document whether the risk has been reduced.

4. Risk Assessment Method

Risk can be estimated by combining the likelihood that a vulnerability will be exploited with the impact on confidentiality, integrity, and availability. For a simple classroom assessment, rate likelihood and impact from 1 (Low) to 3 (High), then multiply the values.

Score	Risk Level	Suggested Response
1–2	Low	Track and fix during routine maintenance.
3–4	Medium	Plan remediation and apply within a reasonable timeframe.
6	High	Prioritize prompt remediation and consider temporary

		safeguards.
9	Critical	Take urgent action; restrict exposure and escalate immediately.

This is a simplified method for educational use, not a formal CVSS calculation. Real assessments should also consider exposure, exploit availability, asset importance, existing controls, and organizational risk tolerance.

5. Example Vulnerability Register

The following are illustrative examples only. They are not findings from a real system. Replace them with verified observations from an authorized assessment.

ID / Finding	Possible Impact	Likelihood	Risk	Mitigation
V-01: Unnecessary open port	Unneeded service may increase attack surface.	Medium (2)	Medium (4)	Disable service or restrict it with a firewall.
V-02: Missing security header	May reduce browser-side defense against a class of attacks.	Medium (2)	Medium (4)	Configure suitable headers and retest.
V-03: Sensitive Android component exported	Other apps may invoke functionality if access controls are weak.	High (3)	High (6)	Disable export where unnecessary; otherwise enforce permissions and authorization.
V-04: Outdated software	Known vulnerabilities may remain unpatched.	High (3)	Critical (9)	Apply vendor security updates and verify the installed version.

6. Recommended Vulnerability Report Fields

- Finding ID and title
- Affected asset, version, or component
- Date identified and assessment scope
- Description and reproducible evidence
- Likelihood, impact, and assigned risk level
- Recommended mitigation and temporary compensating controls
- Responsible owner and target remediation date
- Retest result and final status

7. Mitigation and Prioritization

Mitigation should address the underlying cause rather than only the visible symptom. Common actions include applying security updates, disabling unnecessary services, restricting network access, improving authentication and authorization, validating input, and configuring secure defaults. High-risk findings should receive priority, while low-risk items can be scheduled with routine maintenance. If immediate remediation is not possible, document a compensating control and the reason for the delay.

8. Verification and Follow-up

After a fix is applied, repeat the relevant check to confirm that the weakness is resolved and that normal system functionality still works. Update the finding with retest evidence, date, status, and any remaining risk. A vulnerability should not be marked closed solely because a change was planned; closure requires verification.

9. Conclusion

Documenting vulnerabilities, assigning risk levels, and recommending mitigations helps an organization understand and prioritize security weaknesses. A consistent report records evidence, explains impact, evaluates likelihood, and gives clear corrective actions. Risk-based prioritization allows teams to address the most serious weaknesses first and verify that remediation has been effective.

References

1. NIST, Guide for Conducting Risk Assessments (SP 800-30): https://csrc.nist.gov/pubs/sp/800/30/r1/final
2. OWASP Risk Rating Methodology: https://owasp.org/www-community/OWASP_Risk_Rating_Methodology
3. NIST National Vulnerability Database: https://nvd.nist.gov/